

Web Application Security Assessment

Week 4 Capstone — Penetration Testing Report

Prepared by	Raj Dedakiya
Organisation	Networkwalks
Batch	B082
Mentor	Waqas Karim, CCIE
Assessment Type	Controlled Black-Box Web Security Assessment
Target	https://medirozahospital.com
Classification	Confidential / Educational Use

Assessment objective: identify security weaknesses, validate their practical impact in a controlled environment, document the attack path, and recommend corrective controls.

Prepared as an original report based on the supplied Week 4 capstone workflow. Wording, structure, and presentation have been redesigned rather than copied from the sample report.

1. Assessment Overview

This assessment examined the exposed attack surface of the Mediroza General Hospital web application and followed the available evidence from initial discovery through controlled validation of security weaknesses. The exercise demonstrated how individually manageable weaknesses can combine into a much larger confidentiality risk.

The assessment progressed from reconnaissance and authentication testing to document access, password auditing, metadata review, and finally analysis of an exposed database backup. The resulting chain demonstrated exposure of patient documents as well as internal staff and shareholder information.

Assessment Item	Result
Target	medirozahospital.com
Approach	Black-box / evidence-driven testing
Primary security themes	Authentication, injection, access control, file protection, metadata, server configuration,
Overall risk	Critical
Primary impact	Unauthorised access to confidential organisational information

2. Scope & Rules of Engagement

The assessment was limited to the supplied Mediroza web environment. The sample material states that testing was authorised and excluded social engineering, denial-of-service activity, and testing outside the agreed domain. Findings below are therefore presented as controlled educational validation rather than instructions for unauthorised access.

In scope	Out of scope
Mediroza web application and exposed web paths	Social engineering
Authentication and input-handling behaviour	Denial-of-service testing
Accessible patient-report workflow	Unrelated external systems
Exposed backup and file configuration	Systems outside the authorised target

3. Methodology & Toolset

A staged workflow was used so that each discovery could be tied to the next validation step. This creates a clear evidence trail and avoids treating isolated observations as unrelated issues.

Phase	Purpose	Evidence / Output
Reconnaissance	Map publicly exposed paths and application behavior	Publicly visible routes, responses
Authentication testing	Assess account discovery and login handling	Different login responses; input testing
Controlled exploitation	Validate impact of identified weaknesses	Authorized login-bypass validation and file access
Password auditing	Assess protection of encrypted reports	Hash extraction and wordlist testing
File analysis	Inspect document metadata after authentication	Metadata types and internal comment
Exposure validation	Confirm backup visibility and data sensitivity	Directory listing, SQL backup contents
Reporting	Rank risk and define remediation	Finding register and action plan

Tools referenced in the supplied workflow: curl, browser developer tools, Networkwalks Hash Calculator, Networkwalks Password Cracker, qpdf, exiftool, wget, and ChatGPT for converting the raw SQL records into readable tables.

4. Finding Register

ID	Finding	Severity	Primary impact
F-01	Username enumeration	Medium	Account discovery
F-02	SQL injection in authentication	Critical	Authentication bypass
F-03	Patient reports accessible after bypass	High	Confidential medical-document exposure
F-04	Weak PDF passwords	High	Document protection can be defeated
F-05	Sensitive metadata in PDF	Medium	Internal infrastructure clue disclosure
F-06	Public directory listing for old backup path	Critical	Direct file discovery/download
F-07	Sensitive HR and shareholder data in plaintext	Critical	Mass disclosure of confidential business data

F-01 — Username Enumeration

Severity	Medium
Location	patient/login.php
Observation	The login interface returned distinguishable responses for an unknown username and a known account.
Validation summary	Two test cases were compared: an assumed invalid username produced “Username not found”, while a known account produced “Invalid password”.
Recommended controls	Use one generic authentication failure message for all failed login attempts and add rate limiting, monitoring and logging.

F-02 — SQL Injection in Login

Severity	Critical
Location	patient/login.php
Observation	Input supplied to the username field was incorporated into the database query without adequate parameterisation.
Validation summary	The supplied assessment then used a controlled authentication-bypass test. The resulting behaviour was consistent with a successful login.
Recommended controls	Replace dynamic SQL construction with prepared statements / parameterised queries. Validate input.

F-03 — Patient Reports Reachable After Bypass

Severity	High
Location	patient/reports/
Observation	Following the authorised authentication-bypass validation, three patient report PDFs were available for download.
Validation summary	The supplied workflow identified patient_report_1.pdf, patient_report_2.pdf and patient_report_3.pdf as accessible.
Recommended controls	Enforce server-side authorisation for every document request. Store sensitive documents outside the web root.

F-04 — Weak PDF Passwords

Severity	High
Location	Patient report PDF files
Observation	The three encrypted reports used passwords that were recoverable through wordlist-based password cracking.
Validation summary	Reports 1 and 2 were recovered with the built-in wordlist; report 3 required the larger JTR list. The recovered documents were readable.
Recommended controls	Use strong, unique secrets or centrally managed document encryption. Avoid common passwords and weak encryption.

F-05 — Sensitive PDF Metadata

Severity	Medium
Location	patient_report_3.pdf
Observation	After authorised decryption, document metadata exposed an internal author value and a comment pointing to internal systems.
Validation summary	The supplied workflow used qpdf to decrypt the file and exiftool to inspect metadata. It identified Author: Internal and Comment: Internal systems.
Recommended controls	Sanitise metadata before external distribution. Establish document-release checks and prevent internal information leakage.

F-06 — Publicly Listed Backup Directory

Severity	Critical
Location	/old/

Observation	The old backup directory allowed directory browsing and exposed the SQL backup file directly.
Validation summary	The supplied workflow followed the metadata clue to /old/ and observed the file mediroza_db_backup
Recommended controls	Disable directory indexing, remove obsolete files, keep backups outside the web root, restrict backup

F-07 — Plain-Text Staff & Shareholder Data

Severity	Critical
Location	mediroza_db_backup_2019.sql
Observation	The backup contained highly sensitive HR and ownership information in raw SQL form. The staff tabl
Validation summary	The SQL records were transformed into readable staff and shareholder tables for analysis. The staff c
Recommended controls	Remove exposed backups immediately, encrypt backups at rest, apply strict access controls, establis

5. Attack-Path Reconstruction

The most important lesson from the exercise is the relationship between the findings. The final impact was not dependent on one weakness alone; several weaknesses formed a continuous path from low-level information disclosure to highly sensitive internal records.

Stage	Observed condition	Security consequence
1	Publicly discoverable application paths	Expanded attack surface
2	Different login error messages	Valid account names could be identified
3	Unsafe SQL input handling	Authentication controls could be bypassed
4	Reports available inside the portal	Confidential documents became reachable
5	Weak document passwords	Encryption protection was ineffective
6	Internal metadata in a document	Backup location was disclosed
7	Directory listing on old path	Backup became directly discoverable
8	Sensitive SQL data in backup	Staff and shareholder information was exposed

6. Data Exposure Review

For the reporting portion of the exercise, the raw SQL records were converted into readable tables. Only the fields required by the assessment objective are presented below; unnecessary identifiers and contact fields are not reproduced in this report.

6.1 Shareholder dataset

Shareholder	Share %	Class
Dr. Rajesh Naidoo	18%	Ordinary
Cedar Health Holdings (Pty) Ltd	15%	Ordinary
Dr. Johan van der Merwe	12%	Ordinary
Reddy Family Trust	11%	Ordinary
Thabo Molefe	10%	Ordinary
Sarah Botha	9%	Ordinary
Dr. Ahmed Kara	8%	Preferential
Naledi Zulu	7%	Ordinary
Michael Roberts	6%	Ordinary
Dr. Vikram Chetty	4%	Preferential

6.2 Staff dataset

Name	Job title	Department	Monthly salary (ZAR)
Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	138,000
Sarah Botha	Chief Financial Officer	Finance	152,000
Dr. Johan van der Merwe	Medical Director	Management	160,000
Dr. Anita Naicker	Consultant Cardiologist	Cardiology	132,000

Name	Job title	Department	Monthly salary (ZAR)
Dr. Ahmed Kara	Consultant Physician	Internal Medicine	128,000
Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	74,000
Michael Roberts	HR Director	Human Resources	96,000
Susan Pretorius	HR Officer	Human Resources	32,000
Jameel Malik	IT Systems Administrator	IT	58,000
Thabo Molefe	Network Engineer	IT	46,000
Nomvula Khumalo	Registered Nurse	Emergency & Trauma	34,000
Lerato Mokoena	Registered Nurse	Pediatrics	33,000
Bongani Ndlovu	Registered Nurse	Cardiology	35,000
Zanele Mahlangu	Nursing Sister	Theatre	42,000
Kagiso Sithole	Pharmacist	Pharmacy	61,000
Naledi Zulu	Pharmacy Assistant	Pharmacy	26,000
Themba Nkosi	Radiographer	Radiology	44,000
Palesa Radebe	Radiographer	Radiology	43,000
Deepak Pillay	Lab Technologist	Diagnostics Lab	41,000
Kavitha Govender	Lab Technician	Diagnostics Lab	35,000
Dr. Suresh Moodley	Consultant Radiologist	Radiology	130,000
Dr. Fatima Patel	Pediatrician	Pediatrics	118,000
Nisha Singh	Physiotherapist	Rehabilitation	48,000
Dr. Vikram Chetty	Anaesthetist	Theatre	135,000
David Smith	Facilities Manager	Operations	52,000
Karen O'Connor	Billing Administrator	Finance	29,000
James Wilson	Security Supervisor	Operations	27,000
Linda Fourie	Receptionist	Front Office	19,000
Peter van Wyk	Procurement Officer	Supply Chain	38,000
Andile Mbeki	Ward Clerk	Administration	21,000

7. Remediation Roadmap

Remediation should prioritise the weaknesses that permit unauthorised access or direct exposure, followed by hardening measures that reduce the chance of recurrence.

Priority	Action	Owner / area	Expected outcome
P0	Remove public SQL backup and disable directory listing	Web / Infrastructure	Stops direct backup exposure
P0	Fix SQL injection using prepared statements	Application Development	Prevents authentication query manipulation
P0	Review access controls for every patient document	Application / IAM	Prevents cross-user document access
P1	Rotate and strengthen document/backup secrets	Security / IT	Reduces password-guessing risk
P1	Move backups outside web root and encrypt them	Infrastructure / Backup	Protects backup confidentiality
P1	Strip internal PDF metadata before release	Application / Records	Removes infrastructure clues
P2	Standardise login failure messages	Application Development	Reduces account enumeration
P2	Add logging, alerting and periodic exposure scans	SecOps / IT	Improves detection and prevention

8. Verification Checklist

Control	Verification test	Status target
Authentication	Invalid and valid usernames return the same generic failure	Fail
SQL handling	Special characters do not alter query structure or produce DB errors	Pass
Document access	Unauthorised document requests are rejected server-side	Pass
PDF protection	Weak/common passwords are not accepted	Pass
Metadata	Released PDFs contain no internal operational notes	Pass
Directory listing	/old/ and similar folders do not expose indexes	Pass
Backups	No database dumps are reachable from the public web	Pass
Backup security	Stored backups are encrypted and access-controlled	Pass

9. Conclusion

The assessment demonstrated a high-impact chain in which authentication weaknesses, insecure input handling, insufficient file access controls, weak document passwords, metadata leakage, and an exposed backup collectively increased the likelihood of major confidentiality loss.

The most urgent actions are to remove exposed backups, disable directory indexing, correct the SQL injection, and enforce server-side authorisation for sensitive documents. Once these controls are implemented, the organisation should repeat the assessment to verify that the complete attack chain has been broken rather than validating each issue in isolation.

10. Analyst Reflection

This capstone provided practical exposure to the way a penetration tester connects evidence across different layers of a system. A useful takeaway is that small configuration or development mistakes can become significantly more serious when combined. The exercise also reinforced the importance of documenting evidence clearly, rating findings by business impact, and providing remediation that can be verified after implementation.

11. Assessment Disclaimer

This report is prepared for the controlled educational exercise described in the supplied Networkwalks capstone material. Testing techniques must only be used against systems where explicit permission has been granted. The report should be handled as confidential because the underlying exercise material contains sensitive-looking personal and organisational information.

Prepared by	Raj Dedakiya
Organisation	Networkwalks
Batch / Project	B082 — Week 4 Capstone
Mentor	Waqas Karim, CCIE